



MD Anderson WordPress Plugins: Guide for Leadership and IT

Owner	Montez French, Senior Web Developer, MD Anderson
Code	github.com/mda-dsladmin/wp-plugins
Guide version	1.0, September 2026
Covers	MDA Media Player Fit 1.1.0, Beacon Analytics 1.17.0

This guide explains the WordPress plugins our team builds: what each one is, what it is not, how we use it, what it needs to run, and how it is kept safe. It is a living document. When we add a plugin, we add a section (a template is at the end).

1. The short version

- We build a small set of WordPress plugins in house. Each one does one job.
- All code lives in one GitHub repository. Every site gets updates from there, the same way WordPress updates any other plugin.
- None of our plugins send visitor data to any outside company. No ad trackers, no Google, no Meta.
- Every plugin runs on WordPress 6.0 and newer, and PHP 7.0 through 8.4. That covers our older sites and our newest ones.
- Before release, each plugin went through repeated security reviews. Every problem found was fixed, and each fix has an automated test.

Plugin	What it does	Stores data about visitors?	Calls outside services?
MDA Media Player Fit	Makes embedded videos fit the page at the right shape	No	No (only update checks to GitHub)
Beacon Analytics	Private site analytics, site health scans, and reports	Yes, anonymous only, on our own server	No (only update checks to GitHub)

2. MDA Media Player Fit

What it is

A small plugin that makes embedded videos fill the width of the page at a fixed shape (16:9 by default). It works with YouTube, Vimeo, and the MD Anderson media player.

Why we need it

Some video players, including the MD Anderson media player, do not resize well on their own. On phones the player could be cut off, and the controls could be hidden. This plugin sets the video frame's width and height for the space it is in, and keeps them right as the page changes size (rotating a phone, opening a tab or accordion, resizing a window).

It also fixes an accessibility gap: a video frame with no title gets a short fallback title (for example "Embedded video"), so screen readers can announce it. Titles that already exist are never changed.

How we use it

- Installed on sites that embed videos, such as Pathways.
- Settings are under **Settings > MDA Media Player Fit**: which frames to size, the shape, the fallback title, and an on/off switch for the MD Anderson player fix.
- One video can be skipped by adding `data-mdampf-skip` to it.

What it is not

- It is not a video player. It does not host, change, or play videos.
- It does not track anyone. It sets no cookies and stores nothing about visitors.
- It does not add any outside scripts. Videos load from YouTube, Vimeo, or the MD Anderson player exactly as they did before.

What it stores

Only its own settings (one row in the WordPress options table). Deleting the plugin removes them, on every site of a multisite network.

How it is kept safe

- Only administrators can change settings, and every save is checked with a WordPress security token (a "nonce").
- Every setting is cleaned before it is saved: the shape must be whole numbers from 1 to 100, the title is plain text, and the selector cannot contain `<`.
- Settings reach the page as safely encoded data, so they cannot break out and run as code.
- The page script only changes a frame's width, height, and title, plus the size number in the MD Anderson player link. It never inserts HTML.
- The script cannot get stuck in a resize loop. This was tested in a real browser with tables, grids, animated sidebars, and phone widths from 320 to 1200 pixels.

3. Beacon Analytics

What it is

Beacon is our own website analytics tool. It shows how our pages are used and whether they are healthy, and the data never leaves our own server. It replaces Google Analytics and Google Tag Manager on sites where visitor data must not reach a third party.

It has four screens in the WordPress admin:

- **Dashboard:** page views, unique visitors, visits, top pages, where visitors came from, device types, and US states (optional).
- **Journeys:** the steps of one anonymous visit, and funnels (how many visits finish a set of steps).
- **Site Scan:** checks our own pages for privacy leaks, broken links, SEO, accessibility basics, and content quality, and ranks the fixes.
- **Settings.**

It can also email a scheduled report (CSV, Excel, or PDF) to staff.

Why we built it

Hospital websites have been fined and sued for sending visitor data (an IP address plus the health page someone viewed) to Google and Meta. Beacon has no third party in the path at all. The visitor's browser only talks to the site it is already on.

What it is not

- It is not Google Analytics, and it does not send data to Google, Meta, or any ad company.
- It does not set cookies, and it does not follow a person from one day to the next.
- It does not store IP addresses, names, emails, form entries, full web addresses of other sites, or anything finer than a US state.
- It is not a patient record system. It is meant for public pages, not patient portals or pages behind a login.
- Its tag rules cannot load outside scripts or pixels. That is the gap that makes Google Tag Manager risky, and it is closed by design.

What it stores

One row per page view or click, on our own database:

Stored	Example	Never stored
Page path	/breast-cancer/	Search words, query strings, personal data in the path
Page title	Breast Cancer Treatment	Titles of search and "not found" pages
Referring site	google.com	The full referring address
Device, browser, system	Mobile, Chrome 143, iOS 18	Full browser details, exact screen size
Daily visitor code	a random-looking code	The IP address; the code changes every day

Stored	Example	Never stored
Visit code	a random-looking code	Any cookie or lasting ID
Country and state (optional)	US, Texas	City, ZIP code

Old rows are deleted after the retention period (90 days by default).

How it protects privacy

- **No IP is stored.** The IP is used for a moment to make a daily visitor code, then thrown away. The code is built from the IP's network (a group of addresses shared by many people), not the exact address, and the secret key behind it is replaced every night.
- **Personal data is scrubbed before storage.** Emails, phone numbers, Social Security numbers, dates, and record numbers are removed from page paths and labels, including disguised forms (spelled out, spaced out, encoded, or written with look-alike characters). Page titles get the same check, except that ordinary dates in headlines are kept.
- **Search words never leave the browser.** Search pages report a generic path.
- **Form fields are never read.** Two opt-in features are the only exceptions (below).
- **The collector is locked down.** It only accepts events from our own site, limits how many events one address or visit can send, and refuses oversized requests.

The full technical review, with every claim tied to a file, is in `beacon-analytics/docs/SECURITY-AND-PRIVACY.md`.

Settings that need sign-off before they are turned on

These are all **off by default**. Each one should get approval from the privacy office before use.

Setting	What it does	Why it needs sign-off
Survey capture	Records chosen answers (not typed text) on a survey, like "Question → Answer"	An answer can describe a health situation. Ages over 89 and birth months or days are removed automatically.
Study code capture	Records one research ID field on submit	Makes visits linkable to a study participant. Needs participant consent, IRB or privacy approval, and hosting allowed to hold such data.
Include survey answers in emailed reports	Adds survey results to report emails	Email leaves the server.
External collector	Sends events to another Beacon site instead of this one	Moves where the data is stored.
Check links to other sites	The site scan also checks outside links	Makes the server contact other sites (no visitor data is sent).

4. Compatibility

	Supported	Tested on
WordPress	6.0 and newer	6.0 and 7.1
PHP	7.0 through 8.4	7.0, 7.4, and 8.4
Multisite	Yes	Uninstall cleans every site
Browsers	Current Chrome, Edge, Safari, Firefox, iOS and Android	Headless Chrome, phone and desktop widths

- Both plugins were checked with an automated PHP compatibility scanner for PHP 7.0 and newer, and every file passes a syntax check on PHP 7.0, 7.4, and 8.4.
- The only findings from the scanner are three string functions that WordPress itself provides on older PHP, and a note about a default that does not affect our code.
- Very old browsers without the needed browser feature simply keep the video's original size.
- Beacon's outside-link check needs the PHP curl extension, which almost every host has. Without it, outside links are skipped; nothing else changes.

5. How updates work

For site owners

1. Each plugin's header says it updates from our GitHub repository, so WordPress never looks for it on wordpress.org.
2. About twice a day, WordPress asks GitHub if there is a newer release. If there is, the normal "update now" notice appears on the Plugins screen.
3. To have updates install on their own, click **Enable auto-updates** next to each plugin on the Plugins screen (once per site). Without it, an admin clicks "update now".
4. Under each plugin on the Plugins screen, a **Check for updates** link checks right away and shows the result: an update is available, the plugin is up to date, or the check failed (with the reason).

One-time step for older copies: copies older than Beacon Analytics 1.17.0 or MDA Media Player Fit 1.1.0 do not know about GitHub. Install the new zip once by hand (**Plugins > Add New > Upload Plugin**, then **Replace current with uploaded**). Settings and data are kept. After that, the site updates from GitHub.

Network access: each site's server must be able to reach `api.github.com` (the check), `github.com`, and GitHub's download host `release-assets.githubusercontent.com` (older setups use `objects.githubusercontent.com`) for the zip. If a network blocks these, the check fails and **Check for updates** shows an error. After the first release, click **Check for updates** once on each site to confirm.

No login or token is needed, because the repository is public. On busy shared hosting, GitHub allows 60 checks per hour per server. If a site hits that limit, add a read-only token to `wp-config.php`:

```
define( 'MDA_WP_PLUGINS_GITHUB_TOKEN', 'github_pat_...' );
```

Safety checks on every update

- A site only accepts a download from our repository's own release files, at one exact address per version. Any other address is ignored.
- Versions must be plain numbers (1.2.3). Test and beta releases are skipped.
- The check never follows redirects, so the optional token only ever goes to GitHub.
- A site never downgrades. WordPress only offers a version newer than the one installed.
- If a check fails (for example GitHub's limit is reached), the site keeps the last good answer, so a known update does not vanish.

How a release is published

Everything can be done on the GitHub website. No terminal is needed.

1. Change the plugin's version number in two places in its main file: the `Version:` line near the top and the version constant (`BEACON_VERSION` or `MDAMPF_VERSION`). On GitHub, open the file and click the pencil icon to edit it, or upload the changed files with **Add file > Upload files**.
2. Save the change to the main branch (directly, or through a pull request if main is protected).
3. Go to **Actions > Release plugin > Run workflow**, keep the branch on main, pick the plugin, and click **Run workflow**.
4. The action reads the version from the file, builds the zip, and publishes the release, tagged `<plugin-folder>-v<version>` (for example `beacon-analytics-v1.17.1`). It refuses to publish if the version is not a plain number, the two version numbers in the file do not match, that version was already released, the change is not on main, or the folder contains a symbolic link.

Two other ways work too and run the same checks: publishing a release on the **Releases** page with a new tag named `<plugin-folder>-v<version>`, or pushing that tag from a terminal.

Sites see the update on their next check, or right away with "Check for updates".

6. Security review and testing

What was checked

The review covered the checklist our team uses for web code, plus the risks specific to WordPress plugins.

Area	What protects it
Database attacks (SQL injection)	Every query uses WordPress prepared statements
Script injection (XSS)	Every value shown on a page is escaped; data given to page scripts is safely encoded
Forged requests (CSRF)	Every admin action checks a WordPress security token and the user's role
Who can do what	Settings, reports, and scans are for administrators only; updates need update rights
Bad input	Every field is checked against a strict pattern and length, then cleaned

Area	What protects it
Floods and abuse	Beacon limits events per network, per address, per visit, and site wide
Server tricked into calling internal systems (SSRF)	The scanner only calls public addresses, checks every redirect, and pins each connection to the address it checked
Private data in storage	Scrubbing rules in one file; no IPs; daily keys; retention limit
Report files	Private file permissions from the start, deleted after sending
Spreadsheet formula tricks	Exported cells that could run as formulas are neutralized
Update tampering	Exact download address, plain versions only, releases only from main
Error messages	Nothing internal is shown to visitors

How it was reviewed

- Three rounds of independent, adversarial reviews, each by separate reviewers who tried to break the code, followed by a final check of the last fixes.
- Every problem they found in the code was fixed. The few limits that code cannot fully solve are listed below under "What remains".
- An automated test suite now replays every finding: **217 checks, all passing** on WordPress 6.0 with PHP 7.0, and on WordPress 7.1 with PHP 8.4.
- End-to-end tests also pass on both: data collection, admin screens, reports, site scans, and one-click updates from GitHub.

What remains (honest limits)

- **Pattern matching has limits.** Beacon recognizes the shapes of emails, phone numbers, SSNs, dates, and record numbers, in many disguises. It cannot recognize a bare name typed into a web address. This is why the design does not rely on it alone: query strings, search words, and form fields are never stored in the first place.
- **Some harmless text is removed.** A page path or button with a date or phone number in it (an event page like /events/2025-03-14-walk/, a "Call 713-..." button) is stored as [redacted]. We chose to lose that detail rather than risk storing personal data.
- **Anyone with write access to the GitHub repository can publish an update.** That access is the key control. See the checklist in section 7.
- **The web server itself logs IP addresses,** as every website does. That is a hosting setting, separate from these plugins.
- **Real phones:** the video sizing was tested in a browser at phone widths, not on a physical iPhone. After installing on a site, play one MD Anderson video on an iPhone, rotate it, and check it once.

7. GitHub settings checklist (for IT)

Because sites install whatever our repository publishes, these repository settings are part of the security of every plugin. Hand uploads of zips to a site are still allowed, so access control on who can publish and who can install is what matters.

Setting	Where	Status
Two-factor sign-in required for everyone in the organization	Organization settings > Authentication security	☐
Only named maintainers have write access	Repository > Collaborators and teams	☐
main is protected: changes need a pull request and one approval; no force pushes	Repository > Rules > Rulesets (branch)	☐
Only maintainers can create, move, or delete tags matching *-v* (add GitHub Actions to the bypass list, since the Run workflow button creates the tag)	Repository > Rules > Rulesets (tag)	☐
Releases cannot be changed after publishing (immutable releases), if available. With this on, publish only with the Run workflow button, not the Releases page	Repository > Settings > General	☐
Actions token is read-only by default (the release workflow asks for write itself)	Repository > Settings > Actions > General	☐
Secret scanning and push protection on	Repository > Settings > Code security	☐
Review who has admin rights on WordPress sites (they can install any plugin)	Each WordPress site	☐
Site servers can reach api.github.com, github.com and release-assets.githubusercontent.com (and objects.githubusercontent.com) over HTTPS	Network / firewall	☐

8. Adding a new plugin

Every new plugin in this repository follows the same rules, so this guide stays true.

Build rules

- One folder per plugin at the top of the repository, with a main file of the same name (my-plugin/my-plugin.php).
- Header lines: Requires at least: 6.0, Requires PHP: 7.0, Update URI: <https://github.com/mda-dsladmin/wp-plugins/tree/main/my-plugin>, and the author line Montez French | Senior Web Developer at MD Anderson.
- Copy the updater from an existing plugin and change only the names and slug. Keep the shared cache names the same.
- Add the new folder name to the options list in .github/workflows/release.yml, so it shows up under **Run workflow**.

- No visitor data leaves the site. No outside scripts, fonts, or pixels in visitors' browsers.
- Admin actions check a nonce and the user's role. Every stored value is cleaned; every shown value is escaped; every query is prepared.
- Remove the plugin's own data on uninstall (every site on multisite).

Before the first release

1. Syntax check on PHP 7.0 and 8.4, and the PHP compatibility scan for 7.0 and newer.
2. Test on WordPress 6.0 and the current WordPress.
3. Security review against the table in section 6. Fix every finding and add a test for it.
4. Add the plugin's section to this guide (template below) and to the table in section 1.

Template for a new plugin section

[Plugin name]

What it is: one or two sentences.

Why we need it: the problem it solves.

How we use it: which sites, where its settings are.

What it is not: what it does not do, especially with visitor data.

What it stores: list, or "only its settings".

Outside calls: list, or "none (only update checks to GitHub)".

How it is kept safe: the main protections, and the date and result of its security review.

9. Changes to this guide

Version	Date	Change
1.0	September 2026	First version: MDA Media Player Fit 1.1.0 and Beacon Analytics 1.17.0